

ICDFA GRC102: Information Security Governance

Lab 5: Information Security Governance in Action

Student Name: JOY ORILADE

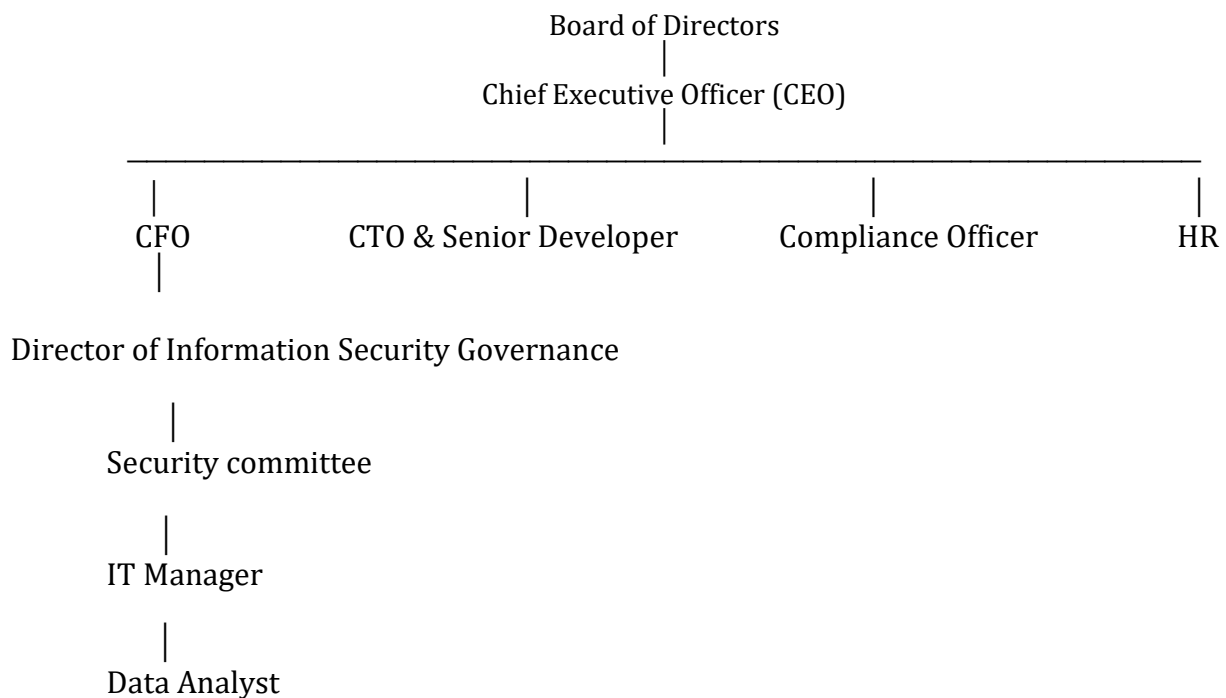
Date: 7TH March, 2026

Instructor: Com Idris Aminu

TASK 1

A. Proposed Security Governance Organizational Chart: A revised organizational chart (you can use a simple text-based or Mermaid diagram like the example above) that clearly shows where the Information Security Governance function sits and its relationship to other departments and leadership.

Proposed Security Governance Organizational Chart



1. Board of Directors:

- **Strategic Oversight:** Ensuring that the security strategy aligns seamlessly with business objectives, approving the overarching security vision, and validating that security investments effectively support business goals.
- **Risk Governance:** Defining the organization's risk appetite and tolerance levels, reviewing and approving the enterprise security risk management approach, and ensuring that major security risks are identified, assessed, and managed appropriately.
- **Resource Allocation:** Approving security budgets and significant investments, ensuring adequate resources are allocated for security programs, and balancing security investments against other critical business priorities.

- **Compliance Oversight:** Ensuring adherence to relevant laws and regulations, reviewing significant compliance issues and their remediation plans, and approving frameworks for managing compliance obligations.
- **Performance Monitoring:** Reviewing the effectiveness of the security program, monitoring key security metrics and indicators, and ensuring the continuous improvement of security capabilities.

2. Chief Executive officer

- **Security Leadership:** Establishing a pervasive security-conscious culture, demonstrating unwavering commitment to security through both words and actions, and ensuring that security considerations are integral to all strategic business decisions.
- **Organizational Structure:** Defining the security governance structure, establishing clear reporting lines for security functions, and ensuring that security leaders are vested with appropriate authority
- **Performance Accountability:** Holding business units accountable for their security performance, regularly reviewing security metrics and program effectiveness, and taking decisive corrective action when security goals are not met.
- **Crisis Leadership:** Leading the organization through significant security incidents, making critical decisions during security crises, and ensuring appropriate communication with stakeholders during such events.

3. Director of Information Security Governance: focuses specifically on the governance, risk, and compliance (GRC) side of cybersecurity, not the entire security program.

Core Focus

- Policy development
- Risk management processes
- Control frameworks
- Compliance monitoring
- Audit coordination

4. Security Committee (CEO, CFO, CTO, Compliance Officer, HR, IT manager): is a Cross-functional decision-making body. It focus on;

- Approve policies
- Review risk posture
- Prioritize remediation
- Align security with business objectives

B. RACI Matrix (Responsible, Accountable, Consulted, Informed): For at least three key security governance activities (e.g., "Policy Approval," "Risk Assessment Review," "Security Incident Response Planning"), define the RACI roles for relevant GHC stakeholders. Use the provided staff list and your understanding of typical organizational roles.

Activity	Board	CEO	CFO	CTO	Director of InfoSec Governance	Compliance officer	HR	IT Manager
Policy Approval	I	A	C	C	R	C	I	I
Risk Assessment Review	I	A	C	C	R	R	C	C
Security	I	A	I	R	R	C	R	C

Incident Response Planning								
----------------------------	--	--	--	--	--	--	--	--

Deliverables for Task 2

1. Completed GHC Information Security Charter: A fully drafted charter document, using the template provided, tailored to GlobalHealth Connect.

ANSWER

GlobalHealth Connect Information Security Charter

1. Purpose

The Information Security Program at GlobalHealth Connect exists to protect the confidentiality, integrity, and availability of all information assets, with particular emphasis on safeguarding Protected Health Information (PHI) and electronic Protected Health Information (ePHI) in compliance with HIPAA, GDPR, and other applicable healthcare regulations. This Charter formalizes the mandate for a proactive, business-aligned security governance framework that supports GHC's strategic goals of market expansion, operational efficiency, customer trust, innovation, and regulatory excellence. By mitigating cyber risks, preventing data breaches, and ensuring secure handling of patient data in our cloud-based patient management systems, the program preserves client trust, minimizes financial and reputational damage, and enables secure innovation in AI-driven tools and data exchange platforms.

2. Scope

This Charter and the Information Security Program apply to all GHC information assets, including:

- All systems, applications, networks, and cloud infrastructure hosting or processing patient management data.
- All forms of data, with priority on PHI/ePHI, sensitive financial information, intellectual property, and employee records.
- All personnel (employees, contractors, third-party vendors), processes, and facilities involved in creating, accessing, storing, transmitting, or disposing of GHC information.
- Post-acquisition integrations from recently acquired startups, ensuring unified security standards across the expanded organization.

The program covers administrative, physical, technical, and operational safeguards to address the full lifecycle of information security.

3. Authority

This Charter is issued under the authority of the CEO and is endorsed by the Board of Directors. The Director of Information Security Governance is granted full authority to:

- Develop, implement, enforce, and monitor information security policies, standards, and procedures.
- Conduct risk assessments, audits, and incident investigations.
- Escalate critical risks directly to the CEO and Board.
- Require cooperation from all departments and personnel to ensure compliance.
- Represent GHC in external regulatory interactions related to information security (in coordination with Compliance).

This authority is derived from the Board's accountability requirements and the CEO's directive to establish formal governance following the recent near-miss data leak.

4. Roles and Responsibilities

High-level roles reference the proposed Security Governance Organizational Chart (Task 1):

- Board of Directors (David Miller - oversight): Provides strategic oversight, reviews key metrics, and ensures accountability.
- CEO: Accountable for overall program success, approval of the Charter, and alignment with business strategy.
- CFO: Consulted on ROI, compliance costs, and financial risk implications.
- CTO: Responsible for technical implementation and integration with development/innovation processes.
- Director of Information Security Governance: Leads the program; accountable for policy development, risk management, compliance monitoring, and reporting.
- Compliance Officer: Co-responsible for regulatory compliance (HIPAA/GDPR) and risk assessments involving PHI.
- Security Steering Committee (cross-functional, chaired by Director of InfoSec Governance): Provides oversight, approves policies, and ensures alignment across IT, Legal/Compliance, HR, Finance, and Development.
- All Employees/Contractors: Responsible for adhering to security policies, reporting incidents, and completing awareness training.

5. Key Principles

The program is guided by the following core principles:

- Risk-Based Approach: Prioritize controls based on identified threats, vulnerabilities, and business impact.
- Business Alignment: Security supports growth, efficiency, innovation, and customer trust without unduly hindering operations.
- Continuous Improvement: Regularly assess maturity, monitor effectiveness, and adapt to emerging threats and regulations.
- Proactive and Preventive: Shift from reactive (ad-hoc) to proactive governance, emphasizing prevention, detection, and rapid response.
- Transparency and Accountability: Clear metrics, open communication, and ownership at all levels.
- Compliance and Ethical Standards: Exceed minimum regulatory requirements to maintain trust in handling sensitive patient data.

6. Reporting Structure

- The Director of Information Security Governance reports directly to the CEO for independence and enterprise visibility.
- Quarterly reports (including key metrics on risk posture, incidents, compliance status, and maturity progress) are provided to the CEO, Security Steering Committee, and Board of Directors.
- Critical incidents or high-risk findings are escalated immediately to the CEO and Board.
- The Security Steering Committee facilitates cross-functional alignment and review.

7. Review and Approval

This Charter will be reviewed annually or following significant events (e.g., major acquisitions, regulatory changes, or incidents) by the Director of Information Security Governance, with input from the Security Steering Committee. Updates require approval by the CEO and endorsement by the Board.

Effective Date: 10TH March, 2026

Approved By: Sarah Chen, CEO

2. Justification Memo: A brief memo (1-2 paragraphs) to Marcus Thorne (CFO) explaining how the proposed charter aligns with GHC's strategic goals and addresses his concerns about clear directives and accountability.

ANSWER

To: The Chief Financial Officer (CFO) - Marcus Thorne

From: Director of Information Security Governance - Joy Orilade

Date: 10th March, 2026

Subject: Alignments of proposed GHC's Strategic goals, security concern and accountability.

Dear Marcus,

The proposed Information Security Charter establishes a formal mandate that directly supports GHC's 2026 strategic goals while ensuring financial accountability and measurable oversight. By clearly defining scope, authority, and reporting structure, the Charter ensures that security investments are risk-based, strategically aligned, and transparently governed.

This document provides the Board with a formal directive for oversight, establishes executive accountability, and ensures that security spending is directly tied to business risk reduction, regulatory compliance (HIPAA and GDPR), operational uptime objectives (99.99%), and protection of market reputation. It transforms security from an ad-hoc cost center into a structured governance function that enables growth, protects revenue, and reduces financial exposure.

I'm available to discuss refinements or present to the Board.

Best regards,

Joy Orilade

Director of Information Security Governance

Task 3: Board Reporting and Metrics

Your Deliverables for Task 3

A. Completed Board Executive Summary: A one-page report, using the provided template, that is ready for the Board of Directors. You must select the most impactful metrics from the raw data, determine the trend, and provide concise commentary.

ANSWER

1. Overall Security Posture: RED

The current security posture is rated RED due to a consistent upward trend in external threats like phishing attempts and malware detection, coupled with rising high-risk incidents and declining patching compliance. While security training completion has improved, these factors indicate heightened business risk, including potential financial losses, reputational damage, and operational disruptions from unaddressed vulnerabilities and incidents.

1. Key Security Metrics

Metric	Current Status	Trends for the last 6 Months	Commentary
High risk incidents	7	Increasing	Increased from 2 to 7 in six months (250% growth). This directly reflects rising operational and regulatory risk exposure.
Phishing attempts	320	Increasing	Increase from 150 to 320 phishing

			attempts which Indicates growing external targeting of GHC systems and staff.
Malware Detections	50	Increasing	Increase from 25 to 50 Malware Detections. the increase in trend indicates increasing attempts to compromise systems, posing risks to data integrity and availability.
Patching compliance	55%	Decreasing	Percentage of critical vulnerabilities addressed; the decline means more unpatched systems, heightening the risk of exploitation by attackers.
Security Training completion	70%	Increasing	Increase from 45% to 70% of security training completion among employee

3. Key Risks and Issues

Rising High-Risk Incidents: The number of high-risk incidents has more than tripled from 2 to 7, indicating potential gaps in defenses that could lead to significant business disruptions or data loss.

Declining Patching Compliance: Compliance has dropped from 67% to 55%, leaving an increasing number of critical vulnerabilities unaddressed from 5 to 18 unpatched, which exposes the organization to known exploits.

4. Recommendations

Enhance Patching Processes: Invest in automated patching tools and dedicate resources to achieve 80% compliance within the next quarter, reducing vulnerability exposure.

Strengthen Threat Defenses: Roll out advanced anti-phishing simulations and malware prevention software, targeting a 20% reduction in attempts and detections over the next six months.

B. Rationale for Metric Selection: A short paragraph explaining why you chose your five key metrics and what they collectively represent about GHC's security posture.

ANSWERS

The High-Risk Incidents, Phishing Attempts, Malware Detections, Patching Compliance, and Security Training Completion were selected because they collectively capture the organization's threat landscape (external attacks), vulnerability management (internal controls), human factors (employee readiness), and overall outcomes (incident impact). These metrics highlight a worsening security posture, with increasing threats and incidents alongside declining remediation efforts, providing a balanced, business-focused view of risks without technical overload.

TASK 4

A. Completed SSC Terms of Reference (ToR): A drafted ToR document for the GlobalHealth Connect Security Steering Committee, using the provided template.

ANSWER

GlobalHealth Connect Security Steering Committee (SSC) Terms of Reference

1. Purpose: The Security Steering Committee (SSC) is established to provide strategic oversight, governance, and direction for GlobalHealth Connect's cybersecurity and information security initiatives. They provide a forum for discussing security strategy, reviewing risk posture, approving policies, overseeing major security projects, and coordinating incident response efforts. The SSC ensures that security strategies align with business objectives while balancing operational efficiency,

innovation, and risk management. The committee serves as a cross-functional decision-making body to resolve security-related conflicts, prioritize security investments, and promote organization-wide security accountability.

2. **Scope:** The Security Steering Committee (SSC) oversees and provides;

- strategic direction, approves major security investments, and reviews overall risk posture.
- Oversees the implementation of the information security program, reviews policy effectiveness, and monitors security performance metrics.
- responsible for managing and coordinating the response to security incidents.
- Focuses on policies and procedures related to data classification, protection, and privacy, often with significant security implications.

3. **Membership:** Typically composed of representatives from various departments, including;

- Chief Executive Officer - CEO
- Chief Financial Officer - CFO
- Senior Developer
- Director of Information Security Governance
- Chief Technology Officer - CTO
- IT Manager
- Compliance Representative
- HR Representative

4. Roles and Responsibilities of Members

- Actively participate in meetings and provide department-specific perspectives.
- Represent their function's priorities while supporting organization-wide security goals.
- Review materials in advance and come prepared to discuss and decide.
- Champion approved security initiatives within their teams.
- Escalate emerging risks or blockers from their areas.
- Commit to confidentiality and constructive, evidence-based dialogue.

5. Meeting Cadence and Logistics

- The SSC will meet monthly and additionally when urgent security matters arise.
- Meetings will be chaired by the Director of Information Security Governance.

The Security Governance team will act as the secretariat, responsible for:

- Preparing meeting agendas
- Recording meeting minutes
- Tracking action items
- Distributing meeting documentation

Meeting minutes and decisions will be circulated to members within 3 business days after each meeting.

6. **Decision-Making Authority:** The SSC has delegated authority to:

- Approve or reject proposed security policies and major controls.
- Prioritize security initiatives and allocate security-related budget within approved limits.
- Resolve inter-departmental conflicts related to security requirements (decisions are final unless escalated to the CEO or Board). Decisions are made by consensus where possible; if consensus cannot be reached, the Chair makes the final call after considering input from all members. Major strategic shifts or items exceeding budget thresholds are escalated to the Board.

7. Reporting

- The SSC provides a quarterly executive summary to the Board of Directors (via the Information Security Report).

- Key decisions, approved policies, risk status changes, and major issues are communicated promptly to relevant stakeholders.
- An annual SSC effectiveness review is conducted, with findings presented to the CEO and Board.

B. Sample SSC Meeting Agenda: A sample agenda for the first SSC meeting, incorporating the password policy conflict as a key discussion item and demonstrating how the SSC would operate.

ANSWER

Sample Security Steering Committee Meeting Agenda

Date: 10th March, 2026

Time: 10:00 AM – 11:30 AM

Location: Virtual (Zoom)

Chair: Joy Orilade, Director of Information Security Governance

Attendees: Sarah Chen (CEO), Elena Rodriguez (CTO), John Smith (IT Manager), Mark Johnson (Compliance Officer), Jane Doe - Senior Developer, John Smith - IT Manager, Robert Green - HR Representative

1. Welcome and Introductions (5 min)

2. Review and Approval of Previous Meeting Minutes (5 min)

First formal meeting – no prior minutes.

3. Action Items Review (10 min)

No prior actions (inaugural meeting).

4. Strategic Security Updates (15 min)

Current security posture overview.

Six-month incident and metrics summary.

5. Key Discussion Topics (30 min)

Discussion Item 1: Proposed Password Policy Review (Addressing CTO's concerns)

Presentation of current proposal vs. industry benchmarks (NIST, NCSC guidance).

Impact assessment: productivity, security risk reduction, shadow IT potential.

Goal: Reach decision or clear path to decision.

Discussion Item 2: Q2 Security Roadmap Prioritization

Top 5 proposed initiatives and resource asks.

6. Risk Register Review (15 min)

Review top 5 organizational security risks and mitigation status.

7. New Business / Open Forum (10 min)

8. Action Items and Next Steps (5 min)

Assign responsibilities and deadlines for follow-ups.

9. Adjournment

C. Briefing Note: A short briefing note (1-2 paragraphs) to Sarah Chen (CEO) explaining how the SSC will help resolve cross-departmental conflicts like the password policy issue and ensure strategic alignment.

ANSWER

Briefing Note to Sarah Chen (CEO)

The establishment of the Security Steering Committee (SSC) directly addresses the current tension between security requirements and business enablement, as seen in the password policy disagreement between the CTO and IT Manager. By bringing key leaders from IT, engineering/product, compliance, finance, and executive leadership together on a regular basis, the SSC creates a structured forum where trade-offs can be openly discussed using data, risk context, and business impact rather than through siloed emails or ad-hoc escalations. This ensures decisions are balanced, transparent, and owned collectively.

The SSC will prevent future similar conflicts from escalating by setting clear policy direction early, aligning security controls with delivery priorities, and fostering mutual accountability. Over time, it will build trust across functions, accelerate decision-making on security matters, and ensure that GHC's security program supports—rather than impedes—innovation and growth while maintaining an appropriate risk posture. I recommend launching the SSC with the sample agenda provided, starting with the password policy as the inaugural discussion item to demonstrate immediate value.

TASK 5

A. Completed Maturity Assessment Table: Fill in the "Current Maturity Score" and "Justification" columns in the table above based on the "Current State Interview Summary."

ANSWER

GOVERNANCE DOMAIN	CURRENT MATURITY SCORE (1-5)	JUSTIFICATION (Based on Interview Summary)
Policy and Documentation	2	Policies exist but are outdated indicating that they are not properly managed and early stage governance practices
Roles and Responsibilities	2	Security responsibilities are not clear across departments. Staff understand security is important but lack ownership
Risk Management	1	There is no formal or proactive risk assessment process, indicating a very early stage of maturity.
Metrics and Reporting	2	Technical metrics are collected, but they are not effectively translated into business-level insights for executives and the Board.
Training and Awareness	2	Security training exists but is limited to annual mandatory sessions with low engagement.
Compliance	2	Compliance activities are largely reactive, with teams preparing for audits only when necessary rather than maintaining continuous

		monitoring.
--	--	-------------

B. Maturity Roadmap: Outline a brief, actionable roadmap (3-5 key initiatives) for GHC to achieve Level 3 maturity across all domains within the next 12-18 months. For each initiative, specify:

- Initiative: (e.g., "Develop and approve a comprehensive Information Security Policy Suite")
- Objective: (What will this initiative achieve?)
- Key Activities: (What steps are involved?)
- Expected Outcome: (What will be the measurable result?)

ANSWER

S/N	Initiative	Objective	Key Activities	Expected Outcome
1	Develop a Comprehensive Information Security Policy Framework	Standardize and formalize security policies across the organization.	• Conduct a policy gap assessment against recognized standards (e.g., NIST CSF / ISO 27001). • Develop a structured policy framework (policies, standards, procedures). • Establish an annual policy review and approval process through the Security Steering Committee.	• A centralized, consistent, and approved policy suite. • All departments operating under standardized security guidelines.
2	Establish a Formal Security Governance and Accountability Structure	Clearly define security roles, responsibilities, and accountability across the organization.	• Develop a security governance model aligned with business structure. • Create a RACI matrix for key security functions. • Formalize responsibilities for IT, development teams, risk management, and compliance. • Integrate governance oversight through the Security Steering Committee (SSC)	• Clear ownership of security responsibilities across departments. • Improved coordination between security, IT, and business teams
3	Security Awareness and Continuous Compliance Monitoring	Improve employee engagement in security awareness while establishing ongoing compliance monitoring.	• Replace annual training with continuous awareness campaigns. • Introduce phishing simulations and interactive training modules. • Implement automated compliance monitoring tools. • Establish periodic internal compliance reviews.	• Increased employee awareness and reduction in human-related security risks. • Improved audit readiness and regulatory compliance.

C. Executive Summary of Assessment: A short summary (1-2 paragraphs) for David Miller (Board Member) explaining the current maturity state and the strategic importance of the proposed roadmap.

ANSWER

Executive Summary of Assessment

The maturity assessment indicates that GlobalHealth Connect currently operates at an early stage of security governance maturity, with most domains scoring at Level 1–2 (Ad Hoc to Initial). While some security practices exist, they are largely informal, inconsistent, and reactive. Policies are fragmented, security responsibilities are unclear, risk management processes are not formalized, and reporting to

executive leadership lacks business-focused insights. This creates potential operational and strategic risks for the organization.

The proposed 12–18 month governance maturity roadmap focuses on establishing foundational governance structures, including standardized policies, defined roles and responsibilities, a formal risk management program, improved security metrics, and strengthened training and compliance practices. By implementing these initiatives, GlobalHealth Connect can achieve Level 3 (Defined) maturity across all governance domains, enabling more consistent security practices, improved risk visibility, and stronger alignment between cybersecurity and business objectives.